

팀명 : 7팀

LLM 추천 패키지 공급망 공격 탐지 도구

작품개요

Python(PyPI)-JavaScript(npm) 패키지를 설치하지 않고 정적 분석으로 검사하는 도구이다. LLM 환각으로 생성된 허위 패키지, 타이포스쿼팅(Typosquatting) 패키지, 정상 패키지의 변조본을 탐지 대상으로 한다.

패키지명을 입력하면 레지스트리 메타데이터 조회, 소스 코드 행위 시퀀스 추출, 49종 악성 지표 분류 체계(활성 매처 36종) 매칭, 6종 공격 시퀀스 패턴 검사, 테인트 분석, Anthropic Claude 3개 에이전트의 합의 검토를 포함한 21단계 절차로 검사한다.

결과는 5단계 위험도(CLEAN / AGENTIC / SUSPICIOUS / HIGH_RISK / MALICIOUS), 발견된 코드의 파일-라인 위치, MITRE ATT&CK 기반 공격 기법 근거를 함께 출력한다. CycloneDX VEX, STIX 2.1, Falco, TAXII 2.1, SafeDep 5종 포맷으로 직렬화해 외부 보안 도구와 연결할 수 있다.

분석을 통과한 패키지에 대한 사후 대응도 함께 둔다. 새 버전이 등록되면 이전 버전과의 AST 차이만 다시 분석해 정상 패키지가 특정 시점부터 변조되는 사례를 따로 잡고, 운영 환경에 깔린 Falco-Tetragon-Wazuh의 의심 행위 알림은 HMAC 서명 webhook으로 받아 관측된 IOC를 학습한 뒤 해당 패키지를 자동 재판정한다.

주 용도는 공격 탐지이지만, 자주 쓰는 패키지의 사전 안전 확인에도 사용할 수 있다.

주요 적용 기술 및 구조

개발 환경	Windows, Docker
개발 도구	Visual Studio Code, Docker Compose, Git
개발 언어	Python, JavaScript / TypeScript
백엔드	FastAPI, SQLCipher, sentence-transformers, tree-sitter
LLM	Anthropic Claude API (3 에이전트 합의)
프론트엔드	Chrome Extension Manifest V3, VS Code Extension API
배포	Docker Compose, systemd
지식 베이스 (자동 수집)	
MITRE ATT&CK 431 techniques / MITRE ATLAS / OWASP LLM Top 10 /	
NIST SSDF v1.1 / SLSA v1.0 / OSV (PyPI + npm) 22만+ advisory /	
GitHub Advisory / OpenSSF Scorecard	
보안 모델	
분석 대상 코드 비실행(정적 분석) / SQLCipher AES-256 위협 DB /	
HTTP API HMAC 서명 인증 (기본 fail-closed, loopback 바인드)	
출력 포맷	
CycloneDX VEX v1.5, STIX 2.1, Falco rules, TAXII 2.1, SafeDep pmg policy	

기대효과

소프트웨어 개발에 생성형 AI 사용이 늘면서, AI 추천을 통한 패키지 도입도 일상화되고 있다. 이 과정에서 AI가 환각으로 생성한 패키지명을 공격자가 미리 등록해두면, 개발자가 의심 없이 설치한 패키지를 통해 악성 코드가 코드베이스에 유입되는 사례가 보고되고 있다. 이런 형태의 공격을 슬롭스쿼팅(Slopsquatting)이라 한다.

본 도구는 개발자와 AI 기반 코딩 사용자가 설치 전에 패키지를 검사할 수 있는 수단을 제공한다. Chrome-VS Code 확장으로 IDE 안에서 검사할 수도 있고, 명령행 도구나 HTTP API로도 호출할 수 있다.

또한 LLM 에이전트 패키지의 새로운 위협(Prompt Injection, Tool Hijacking)을 분류하기 위한 AISLOPSQ Manifest 형식을 함께 제안한다. 패키지가 자신의 capability 경계를 선언하고 정적 분석으로 탐지된 실제 행위와 대조하는 투명성 표준으로, 작성자의 자기선언은 코드 시그니처로 뒷받침될 때만 위험도 완화에 반영된다.

팀 구성

지도교수 : 이강신

백동진 : 주제 선정, 자료 조사, 보고서 작성

김의재 : 시스템 아키텍처 설계, 분석 엔진 개발, 환각 데이터셋 구축

정유진 : 자료 조사, 환경 구축, Extension 개발
강민승 : 자료 조사, Extension 보완, 환각률 측정

팀별 코멘트

본격적으로 조명되기 시작한 지 얼마 되지 않은 취약점이라 참고할 자료가 많지 않았고, 자료 조사와 방향 구상부터 쉽지 않았습니다. 특히 패키지 생성 시점이나 등록 여부 같은 단편적 지표만으로는 부족하다고 판단해, 더 정밀한 지표들을 찾아 로직을 다시 구성하는 과정이 가장 까다로웠습니다.

연구가 덜 진행된 주제를 직접 파고들어 결과물을 만드는 과정에서 AI 환경의 보안 위협을 구체적으로 이해할 수 있었습니다. 막막한 순간도 있었지만, AI를 사용하는 한 마주할 수밖에 없는 위협을 미리 들여다볼 수 있었던 점에서 의미 있는 시간이었습니다.